

정기감사
공개용

부산대학교병원 정보전산팀 · 정보보안팀 감사결과 보고서



2024. 5. 13.

부 산 대 학 교 병 원 감 사 실



차 례

I. 감사실시 개요	3
1. 감사배경 및 목적	3
2. 감사중점 및 대상	3
3. 감사실시 과정	3
4. 감사결과 처리	4
II. 감사대상 현황	5
1. 정보전산팀	5
2. 정보보안팀	10
III. 감사 결과	14
1. 정보전산팀	14
2. 정보보안팀	16
IV. 처분요구와 통보사항	18
1. 처분요구사항 일람표	18
2. 신분상 조치인원 명세	19
3. 처분요구상세	19
가. PHIS 메뉴 권한 부여 절차 미흡	20
나. 전산장비 수리(구입) 관련 업무 운영 미흡	22
다. 예산 통합 운영 부적정	27
라. 복무 관리 부적정	30
마. 정보보호 및 개인정보보호 업무 운영에 관한 사항	33
바. 네트워크 및 프로그램 설치에 대한 관리 미흡	38
사. VPN 사용승인 및 관리 미흡	42
아. 유지보수 용역 관리에 관한 사항	45
자. 복무 관리 부적정	49

I 감사실시 개요

1. 감사배경 및 목적

부산대학교병원 감사실은 부산대학교병원 정보전산팀 및 정보보안팀(이하 ‘정보전산팀’, ‘정보보안팀’이라 한다)의 주기능·주임무와 조직, 인사, 예산 등 업무 전반의 적법성, 타당성 등을 점검하고 업무상 고충과 불합리한 관행, 업무 시스템의 취약점 등 문제점에 대한 시정 및 개선 대안을 제시함으로써 업무의 효율성과 합리성을 높이고, 궁극적으로 병원 경영을 지원하기 위하여 2024년도 부산대학교병원 감사실 자체 감사계획에 따라 정보전산팀, 정보보안팀에 대한 정기감사를 실시하였다.

2. 감사중점 및 대상

이번 감사는 정보전산팀, 정보보안팀 현안사항 중 제도적·정책적으로 대안 제시가 필요한 부분을 찾아내고 합리적인 제도 개선을 통해 부서 업무를 지원할 수 있도록 하는데 감사의 중점을 두었다. 따라서 정보전산팀, 정보보안팀에서 제출한 감사자료¹⁾를 토대로 주요 업무 수행 과정이 관련 법령 및 병원 규정과 정책 등을 준수하는지 여부, 종전 정기감사 지적사항에 대한 이행 여부 등을 확인하고, 더불어 소속 직원들에 대한 복무관리 실태, 부서 예산 집행내역 등과 같은 부서 운영의 적정성도 점검하였다. 감사 범위는 정보전산팀, 정보보안팀에서 2021. 1. 1.부터 2023. 12. 31.까지 수행한 업무에 한하여 검토하였다.

3. 감사실시 과정

실지감사에 앞서 기존의 감사결과 및 공공감사정보시스템, 공공기관 알리오

1) 정보전산팀-1390(2024.04.04.) ‘부산대학교병원 정보전산팀, 정보보안팀 정기감사 실시통보 및 감사자료 제출 요구에 대한 회신’

등을 통하여 감사 자료를 수집·분석했고, 이후 예비조사(2024. 4. 8. ~ 2024. 4. 12.)를 거쳐 2024. 4. 15.부터 2024. 4. 26.까지 10일간 내부감사인 8명과 국립대학교병원 협동감사제도를 활용한 외부감사인²⁾ 1명을 투입하여 실지감사를 실시하였다.

두 부서의 분야별 주요 쟁점을 확인하기 위해 ①주요 업무분야에서는 정보체계 개발 계획의 수립·분석·설계에 관한 사항, 전산기기 도입 계획의 수립에 관한 사항, 전산시스템 및 프로그램 운용 및 보완에 관한 사항, 정보보호 관리체계 수립 및 운영에 대한 관리 및 점검, 정보보호 관련 인증 및 감사에 관한 사항, 침해사고 예방·분석·대책 수립에 관한 사항을 중점적으로 확인하였고, 그 외 업무에 수반되는 행정지원 전반에 관한 사항 등도 제공받은 서류와 전자문서를 열람하여 검토하였다. 또한 ②부서 운영의 적정성을 확인하기 위해 경비정산 내역 및 예산 관리 현황을 점검했으며, ③복무관리 실태를 점검하기 위해 부산대학교병원 그룹웨어 및 병원정보시스템인 'PHIS'에서 출장·휴가 등의 데이터를 추출하여 활용하였다.

4. 감사결과 처리

감사결과, 개선사항 및 시정·관리가 요구되는 사항 등에 관련하여 정보전산팀, 정보보안팀으로부터 의견을 듣고 이견을 조정하기 위해 정보전산팀장, 정보보안팀장 등이 참석한 가운데 2024. 4. 26.(금) 감사마감 회의를 실시하고 주요 지적사항 등에 대한 의견을 교환하였다. 이후 감사실에서는 지적사항에 대한 내부 검토 및 상임감사의 결재(2024. 5. 13.(월))를 거쳐 감사결과를 최종 확정하였다.

2) 교육부 감사총괄담당관-1765(2024.04.09.) '국립대학교병원 협동감사 인력 지원 알림'

II 감사대상 현황

1. 정보전산팀

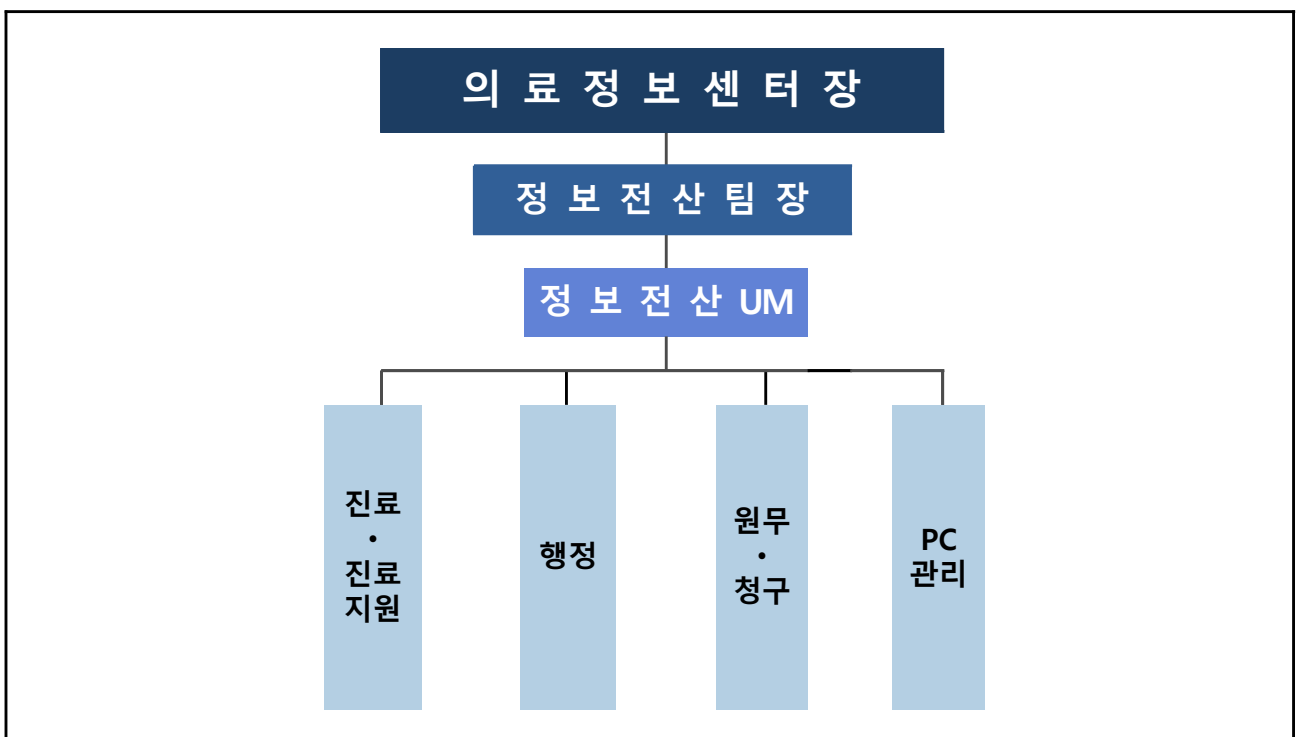
가. 부서운영분야

(1) 조직·인원 현황

정보전산팀은 보다 안정적인 의료 서비스 환경을 구축하고 전 직원이 효율적인 업무를 수행할 수 있도록 정보시스템을 개발하고 정보 체계를 마련해가는 부서로서 「직제규정」 제18조의4에 따라 의료정보센터 아래에 설치되어 있다.

조직 구성원은 팀장 1명, UM 1명, 팀원 15명 등 총 17명으로 구성되어 있으며 조직도는 [그림 1], 인력 현황은 [표 1]과 같다.

[그림 1] 정보전산팀 조직도



[표 1] 정보전산팀 인력 현황

(단위: 명)

연도	구분	2급	3급	4급	5급	6급	7급	8급	가급	소계	계약직	총계
2021	전산직	1	3	6	4	1				15	2	19
	원무기술직							1	1	2		
2022	전산직	1	3	6	4	1				15	2	19
	원무기술직						1	1		2		
2023	전산직	2	3	6	4	1				16		18
	원무기술직						1	1		2		

※ 기준일: 각 연도별 12. 31. (2024년 인원은 퇴직자 1명을 제외하여 17명임.)

(2) 부서예산 현황

최근 3년간 정보전산팀의 예산 배정 및 집행내역을 확인한 결과는 [표 2]와 같다.

[표 2] 정보전산팀 예산집행 현황

(단위: 원, %)

연도 \ 구분	예산액	집행액	잔액	집행률
2021 ¹⁾	4,918,707,000	2,220,491,340	2,698,215,660	45.1
2022 ²⁾	8,274,619,000	2,544,785,108	5,729,833,892	30.8
2023	7,458,173,000	5,676,092,858	1,782,080,142	76.1

※ 집행률이 70% 이하인 사유: 아래 항목의 예산이 병원 경영사정상 집행이 유보됨.

1) 2021년

- 복구솔루션 (192,500,000원)
- 망 분리 시스템 구축 (434,380,000원)
- 랜섬웨어 방지 솔루션 (202,235,000원)
- 스팸메일 차단 솔루션 (231,000,000원)
- 시스템 접근제어 및 보안감사 솔루션 (131,818,000원) 등

2) 2022년

- 메인시스템 교체 (3,535,781,000원)
- 망 분리 시스템 구축 (459,974,000원)
- 랜섬웨어 방지 솔루션 (202,235,000원)
- 개인정보 유출 차단 솔루션 고도화 (310,000,000원)
- 통합 로그 수집 시스템 고도화 (297,000,000원) 등

나. 주요업무 및 추진실적

(1) 주요업무 내용

정보전산팀 주요업무는 [표 3]과 같다.

[표 3] 정보전산팀 업무분장

직위	업 무 내 용
팀장	정보전산팀 업무 총괄
UM	- 원무/청구 총괄 - ABC, CDM 관련 업무
팀원 (진료 및 진료지원)	- 처방 관련 업무 - 간호(간호기록/가정간호/완화의료) 관련 업무 - 의무기록(EMR/서식생성/전자인증) 관련 업무 - 의료질관리 관련 업무 - 심뇌혈관/연명 관련 업무 - 감사/위험/사고/시설/보건(직원검진) 관련 업무 - 병리과 관련 업무 - 영양 관련 업무 - 약국(KIMS) 관련 업무 - 진료정보교류 관련 업무 - 그룹웨어 관련 업무 - 진단검사(혈액은행) 뇌은행 관련 업무 - 예방접종 관련 업무 - NEDIS(응급실/외상) 관련 업무 - 수술/마취 관련 업무 - 치료실(방종/물리치료/인공신장/복막투석) 관련 업무 - 고객지원(SMS/카카오톡) 관련 업무
팀원 (행정)	- 인사급여 관련 업무 - 간호교육/간호행정 관련 업무 - 물류관리(구매재고/고정자산/중앙공급실) 관련 업무 - 재무회계(경영성과) 관련 업무 - 예산관리(의료장비수익) 관련 업무 - 메신저업무 관련 업무

직위	업 무 내 용
팀원 (원무 및 청구)	• 원무(외래), 사회사업, 발전후원, 민원 관련 업무 • 청구(외래), 국제진료/국가암검진/건강증진 관련 업무 • 원무(입원/원무미수/성과급) 관련 업무 • 원무공통(원무통계/대진 의사), 성과급 관련 업무 • 청구(입원/보험미수/수가관리/EDI수신) 관련 업무
팀원 (PC관리)	• PC 관리(PC 신규/이전설치/수리) 관련 업무 • 네트워크 관련 업무

(2) 주요업무 추진실적

최근 3년간 정보전산팀의 주요업무 추진실적은 [표 4]와 같다.

[표 4] 정보전산팀 주요업무 추진실적

연도	건명 및 사업내용	사업목적	현황 및 실적	사업성과
2021	○ 입원 무인수납기 도입	- 비대면 수납을 통한 창구 대기 시간 축소 - 원무 창구 인력난 지원	- 2021년 12월 입원 무인수납기 설치 및 시범 운영 - 2022년 1월 정식 오픈	- 원무 입원 대기인원 및 대기 시간 감소 - 환자 편의성 증대 및 민원 감소
	○ 코로나19 동선 추적 프로그램 개발	- 코로나19 환자의 폭발적 증가로 확진자 접촉 현황을 신속하고 편리하게 알 수 있는 프로그램을 개발함.	- 2021년 3월 프로그램 개발완료 및 TEST - 2021년 8월~9월 현업 요청사항 추가 개발	- 코로나19 추가감염을 최소화하고 직원 및 환자의 안전을 도모함
	○ 외상센터 외상인력관리 프로그램개발	- 외상센터 각종 평가에 대응하고 외상전담 인력관리를 위한 시스템 개발	- 외상간호사인력 관리 및 평가표 개발 - 기간별 외상전문 인력 현황 개발(2021년 5 ~ 6월)	- 정확하고 신뢰할 수 있는 외상전담인력관리 가능
	○ 인티팜 장비 연동 프로그램 개발	- 인티팜(자동 약품 분배 캐비닛 시스템) 장비가 도입됨에 따라 PHIS 시스템을 해당 장비와 연동되도록 프로그램 개발	- 2021년 2월: 프로그램 개발, 테스트 운영 - 2021년 2월 말: 개발완료 및 오픈	- 정확한 조제 및 업무 효율성 증가
2022	○ PDA 기반 환자 안전관리 시스템 전 병동 확대	- 바코드 또는 RFID를 통한 정확한 환자 인식 필요 - 환자의 처방과 일치하는 약물, 혈액을 투여함으로써 오류 방지	- 2022년 5월 31일: 계약 체결 - 2022년 6월~9월: PDA 전 병동 공급 및 프로그램 업그레이드 진행 - 2022년 10월: 오픈 및 안정화	- 수혈 및 약물 투여 정확도 향상
	○ KIOSK 업체변경 및 고도화 작업	- 신규장비 증설 및 수납/처방전 출력 프로그램의 교체 및 고도화 - 전체 수납창구 지능형	- 2022년 7월 1일: 키오스크 장비 변경 및 순번시스템 확대도입 - 2022년 9월 15일: 무인	- 고객대기시간 감소 - 환자편의성 증가

		- 순번대기 시스템 확대 도입 - 무인 제증명 발급시스템 도입	제증명 발급시스템 도입	
	○ 항암 Flow Sheet 노트	- 항암 환자의 통합적 평가 및 공유를 위함.	- 프로토콜에 따른 항암제 처방리스트 및 투여량 연동 - 검사결과 연동 및 각 계산값에 맞는 구간 체크기능 구현	- 항암제 처방 및 투여 오류 예방 개선활동에 기여
	○ 주사약 자동 조제 시스템 연동	- 주사약 자동 조제 시스템이 구축됨에 따라 PHIS시스템을 해당 장비와 연동 되도록 프로그램 개발	- 2022년 6월~7월: ADS 연동을 위한 PHIS 프로그램 개발 - 2022년 8월~9월: 테스트 및 개발완료	- 신속하고 정확하게 약을 불출할 수 있도록 함
2023	○ 신용카드 결제서비스시스템(VAN) 변경작업 지원	- 안정적인 신용카드 결제서비스시스템(VAN) 구축 및 전환을 위한 지원 작업 - 다양하고 안정된 결제 Infra구축	- 공개입찰결과 기존업체가 재선정 되어 보다 안정적인 서비스를 지속적으로 제공하게 되었음	- 편리한 방식의 신용카드 결제 서비스시스템(VAN) 구축함으로써 고객만족도 증대
	○ 외과계 중환자실 예약관리	- 기존 구두예약은 정확한 의사소통이 어려움 - 담당의, 마취의 및 중환자실 간호사 등 의료진 간 정보 공유 목적	- 외과계중환자실 입실 관리 전산화 - 외과계중환자실 빈 병상을 일별로 입력하여 입실 입력시 참조되도록 구현	- 중환자실 병상관리 효율화 - 예약방법 전산화를 통한 중환자실 업무 부담 감소
	○ 영상검사 위험요인 확인 및 공유를 위한 전산프로그램 개발	- 2022년 FMEA 활동 일환으로 본원 영상검사 프로세스 검토 및 도식화 - 조영제 부작용 및 MRI 위험요인에 대해 EMR 연계하여 정보표시 필요성	- 기존 검사목적, MRI 위험요인을 통합 - 조영제 부작용 관련사항을 세분화하여 통합 화면으로 적용	- 영상검사 프로세스 검사 전 확인사항의 표준화 및 간편화 - 조영제 부작용 위험요인 세분화하여 재확인
	○ 수혈체크리스트 확대	- 원내에서 시행된 수혈에 대한 적정성 평가를 시행	- 2023년 2월: 프로그램 개발 - 2023년 3월: 테스트 및 오픈	- 수혈 처방의 적정성 평가에 대한 정확도 및 효율성 개선
	○ 디지털병리시스템 연동 개발운영	- 현미경으로 관찰하던 판독을 스캔이미지로 변환하여 처리 - 판독스캔자료 데이터베이스 구축	- 병리검사 판독(조직, 분자, 면역) 데이터 스캔, 데이터처리 보관	- 디지털데이터의 지속성, 연속성 향상

다. 부서 운영경비 사용 현황

최근 3년간 정보전산팀의 부서 운영경비 사용 현황은 [표 5]와 같다.

[표 5] 정보전산팀 부서 운영경비 사용 현황

(단위: 천원, %)

연도 업무추진비내역	2021			2022			2023		
	수입	비용	집행률	수입	비용	집행률	수입	비용	집행률
부서운영경비	4,665	4,665	100	5,040	4,260	84.5	4,905	4,745	96.7

2. 정보보안팀

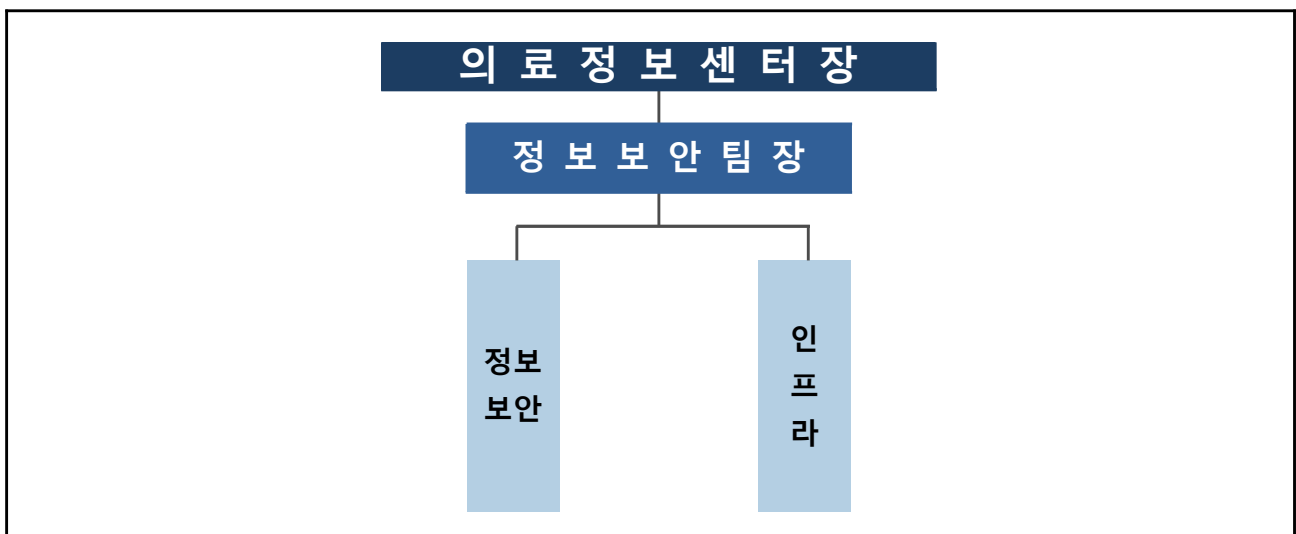
가. 부서운영분야

(1) 조직·인원 현황

정보보안팀은 정보보호의 법적 책임과 의무 준수를 위해 정보보호 관리체계 (ISMS) 수립 및 운영 업무를 담당하고 있으며, 정보시스템 취약점 개선을 통한 정보시스템의 보안 강화 및 내부통제 업무를 수행하는 부서로서 「직제규정」 제 18조의5에 따라 의료정보센터 아래에 설치되어 있다.

조직 구성원은 팀장 1명, 팀원 4명 등 총 5명으로 구성되어 있으며 조직도는 [그림 2], 인력 현황은 [표 6]과 같다.

[그림 2] 정보보안팀 조직도



[표 6] 정보보안팀 인력 현황

(단위: 명)

연도	구분	2급	3급	4급	5급	6급	7급	8급	소계	계약직	총계
2021	전산직		1		2	1			4		5
	원무기술직				1				1		
2022	전산직		1		2	1			4		5
	원무기술직			1					1		
2023	전산직		1		2	1			4		5
	원무기술직			1					1		

※ 기준일: 각 연도별 12. 31.

(2) 부서예산 현황

※ 정보전산팀 예산 현황 참조(현재 정보전산팀 예산과 통합하여 관리함.)

나. 주요업무 및 추진실적

(1) 주요업무 내용

정보보안팀 주요업무는 [표 7]과 같다.

[표 7] 정보보안팀 업무분장

직위	업 무 내 용
팀장	정보보안팀 업무 총괄
팀원 (정보보안)	(개인)정보보안(ISMS/주요정보통신) 관련 업무 - 네트워크(무선/NMS) 관련 업무 (개인)정보보호 정책 수립 및 제·개정 검토 (개인)정보보호 관련 예산 편성 및 집행 - 정보보호 관리체계 수립 및 운영에 대한 관리 및 점검 (개인)정보보호 활동 및 운영 현황 점검 및 감독 - 정보시스템 취약점 진단 및 개선조치 (개인)정보보호 관련 인증 및 감사에 관한 사항 - 침해사고 예방, 분석, 대책 수립에 관한 사항 - 공공기관 개인정보보호 관리수준진단에 관한 사항 - 기타 개인정보보호 및 정보보안에 관한 사항
팀원 (인프라)	- 시스템 관련 업무 - 데이터베이스 운용 및 관리에 관한 사항 - 각종 정보의 생산, 제공 및 보존에 관한 사항 - 전산기자재(PC 및 프린터 등) 관리에 관한 사항

(2) 주요사업 추진실적

최근 3년간 정보보안팀의 주요사업 추진실적은 [표 8]과 같다.

[표 8] 정보보안팀 주요사업 추진실적

연도	건명 및 사업내용	사업목적	현황 및 실적	사업성과
2021	○ 정보보호 관리체계 (ISMS) 사후1차 심사	- 우리병원은 정보보호 관리체계(ISMS) 인증 의무대상자(정보통신망법 제47조 2항)로 중요정보 유출과 외부로부터의 보안 위협을 예방하고 정보보호 관리체계를 수립하기 위함.	- 2021년 10월: 사후 1차 현장심사 실시 - 2022년 1월: 조치 내역서 제출 및 현장 이행점검 실시 - 2022년 1월: 심사결과 "인증유지"	- 정보보호 관리체계 (ISMS) 인증서 획득 - 정보시스템 보안 신뢰도 향상
	○ 서버팜 스위치 교체	- 사용 중인 서버팜 장비의 제조사 서비스 지원 종료(EOS)로 신규 서버팜 장비를 구축하여 운영의 안정성을 확보하고자 함.	- 2021년 5~6월: 입찰 - 2021년 12월: 제품 도입 및 세팅	- 신규 장비 도입으로 인한 중요 서버 통신의 안정성 확보
2022	○ DDoS 대응체계 강화를 위한 모의훈련	- 주요 정보통신 기반 시설 취약점 분석 평가 항목, 관리영역 A-38(DDoS 대응체계를 수립하고 주기적인 훈련을 실시하고 있는가)을 준수하기 위함.	- 2022년 11월, 2022년 12월: 모의훈련 실시 - 2022년 8월: 보호대책 수립 후 관련 자료 교육부로 제출	- DDoS 공격에 대처하기 위한 복구체계 점검
	○ 원내 노후화 PC 교체	- PHIS 오픈(2011.01)시 구입한 노후화 PC 약 1,200대 중 약 700여대의 PC를 신규 교체함.	- 2022년도 상반기 중 약 700대 교체 실시 함.	- 향상된 업무처리속도 및 사후관리 용이
2023	○ 주요 정보통신 기반시설 보호 대책 수립을 위한 컨설팅 및 보호대책 수립	- 정보통신기반보호법 제5조(주요 정보통신 기반시설 보호대책의 수립 등), 법적 의무사항을 준수하기 위함.	- 2023년 6월: 컨설팅 계약 체결 - 2023년 7월: 컨설팅 진행 - 2023년 8월: 보호대책 수립 후 교육부 제출 완료	- 기반시설 침해사고 예방 및 대응능력 강화

다. 부서 운영경비 사용 현황

최근 3년간 정보보안팀의 부서 운영경비 사용 현황은 [표 9]와 같다.

[표 9] 정보보안팀 부서 운영경비 사용 현황

(단위: 천원,%)

연도 업무추진비내역	2021			2022			2023		
	수입	비용	집행률	수입	비용	집행률	수입	비용	집행률
부서운영경비	750	750	100	780	0	0	780	687	88

※ 2022년 부서운영경비 집행률 저조 사유: 코로나19 발생으로 인한 모임 제한 권고로 부서 모임 활동 불가하여 부서 운영경비 전액 반납함.

III 감사결과

1. 정보전산팀

정보전산팀 감사결과, 총 4건의 부당 · 개선 사항에 대한 처분을 종류별로 구분하면 [표 10]과 같으며, 감사결과 주요 사항을 요약하여 정리하면 아래와 같다.

[표 10] 정보전산팀 지적사항 총괄

(단위: 건)

합계			변상 명령 (금액)	징계 (인원)	시정 (금액)	주의 (인원)	경고 (인원)	개선	권고	통보					고발 (인원)	현지 조치
건수	금액	인원								일반	시정 완료	인사자료 (인원)	비위 (인원)	모범 사례		
4								2	1	1						

정보전산팀 감사결과 확인된 주요 사항

<감사지적사항>

☐ PHIS 메뉴 권한 부여 절차 미흡

- 타 부서 PHIS(EMR 프로그램) 메뉴 권한 부여 시 관련 부서 협조 결재 누락

☐ 전산장비 수리(구입) 관련 업무 운영 미흡

- 전산장비 수리(구입) 관련 업무의 이원화
- 전산장비 수리(구입) 관련 업무 기록 및 이력 관리 미흡
- 전산장비(수리/구입)의뢰서 결재권자의 결재 누락

☐ 예산 통합 운영 부적정

- 직제 분리된 두 팀(정보전산팀, 정보보안팀)이 예산을 통합 운영하여 규정에 미부합

☐ 복무 관리 부적정

- 각종 휴가 사후 승인 및 육아휴직 미신청
- 출장복명서 미제출

정보전산팀은 병원의 대내외적인 업무가 원활하게 진행될 수 있도록 통합의 료정보시스템을 운영하며 체계화된 정보시스템의 개발 및 운용에 힘쓰고 있으며, 향후 ICT신기술, 빅데이터 등 디지털 혁신 기술 도입과 의료 질 향상을 위한 차세대 통합 병원정보시스템을 구축하고자 추진 중에 있다.

그러나 이번 감사를 통해 정보전산팀, 정보보안팀이 예산이나 업무 관련 사항을 보다 명확하게 구분하여 운영할 수 있도록 협의 및 조치가 필요하였고, ‘PHIS 메뉴 권한 부여 절차 미흡’ 외 3건의 지적 사항에 대해서는 향후 이러한 일이 재발하지 않도록 개선 및 권고 등의 처분을 요구하였다.

2. 정보보안팀

정보보안팀 감사결과, 총 6건의 부당 · 개선 사항에 대한 처분을 종류별로 구분하면 [표 11]과 같으며, 감사결과 주요 사항을 요약하여 정리하면 아래와 같다.

[표 11] 정보보안팀 지적사항 총괄

(단위: 건)

합계			변상 명령 (금액)	징계 (인원)	시정 (금액)	주의 (인원)	경고 (인원)	개선	권고	통보					고발 (인원)	현지 조치
건수	금액	인원								일반	시정 완료	인사 조치 (인원)	비위 (인원)	모범 사례		
6 (7)						3 (7)			1	2						

정보보안팀 감사결과 확인된 주요 사항

<감사지적사항>

☐ 정보보호 및 개인정보보호 업무 운영에 관한 사항

- 정보보안팀 전담조직 역할 미이행
- 규정과 지침에서 정한 업무 담당부서 상이

☐ 네트워크 및 프로그램 설치에 대한 관리 미흡

- 서비스 신청 내역 및 원내프로그램 설치 부분 검토 미흡

☐ VPN 사용 승인 및 관리 미흡

- 각 지침에서 정한 '사용승인 권한자' 상이(현행상 실제 업무 담당자 승인)
- VPN 사용에 대한 검토 사항 미흡

☐ 유지보수 용역 관리에 관한 사항

- 용역별 특수조건에 명시된 유지보수 업무 범위 미이행
- 유지보수 업무 직제규정 및 업무분장규정 상 정보전산팀으로 규정
: 현재 양팀(정보전산팀, 정보보안팀)에서 업무 수행

☐ 복무 관리 부적정

- 각종 휴가 사후 승인 및 출장복명서 미제출

정보보안팀은 의료기관을 대상으로 지속적으로 발생하는 사이버 위협으로부터 대응하기 위해 시스템 보안 수준을 향상시키고 정보보호체계(ISMS)의 수립 및

운영을 통해 정보자산을 보호하고자 지속적인 노력을 기울이고 있다. 그러나 이번 감사를 통해 ‘정보보호 및 개인정보보호 업무 운영에 관한 사항’ 외 4건의 지적 사항에 대해서 면밀한 검토를 통한 적절한 운영방안을 마련하는 것이 요구 되었으며, 향후 이러한 일이 재발하지 않도록 주의 및 권고 등의 처분을 요구하였다.

IV 처분요구와 통보사항

1. 처분요구사항 일람표

일련 번호	감사대상 부 서	건 명	처분요구			조치 기한	비고
			처분 종류	재정상 조치금액	신분상 조치인원		
1	정보 전산팀	PHIS 메뉴 권한 부여 절차 미흡	개선	-	-	처분 후 2개월내	
2		전산장비 수리(구입) 관련 업무 운영 미흡	권고	-	-	"	
3		예산 통합 운영 부적정	개선	-	-	"	
4		복무 관리 부적정	통보	-	-	"	
5	정보 보안팀	정보보호 및 개인정보보호 업무 운영에 관한 사항	권고	-	-	"	
6		네트워크 및 프로그램 설치에 대한 관리 미흡	주의	-	2명	"	
7		VPN 사용 승인 및 관리 미흡	주의	-	2명	"	
8		유지보수 용역 관리에 관한 사항	주의 통보	-	3명	"	
9		복무 관리 부적정	통보	-	-	"	

2. 신분상 조치인원 명세

건명	처분내역			
	조치결과	소속	직급	성명
네트워크 및 프로그램 설치에 대한 관리 미흡	주의	정보보안팀	전산 ◎급	○○○○
		정보전산팀	전산 ●급	●●●●
VPN 사용 승인 및 관리 미흡	주의	정보보안팀	전산 ◇급	◇◇◇◇
		정보전산팀	전산 ◆급	◆◆◆◆
유지보수 용역 관리에 관한 사항	주의	정보보안팀	전산 ♡급	♡♡♡
		정보전산팀	전산 ☒급	☒☒☒
		정보전산팀	전산 ■급	■ ■ ■

3. 처분요구상세

부 산 대 학 교 병 원

개 선

제 목 PHIS 메뉴 권한 부여 절차 미흡

소관부서 부산대학교병원 정보전산팀

조치부서 부산대학교병원 정보전산팀

내 용

1. 업무개요

부산대학교병원 정보전산팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보체계 개발 계획·분석·설계, 전산기기 도입 계획·설치운용·유지 보수, 전산시스템 및 프로그램 운영·보완 등의 업무를 수행하며 병원 전산 업무 전반에 대한 정보 관리 및 운용의 핵심 기능을 담당하고 있다.

2. 관련근거(판단근거)

「부산대학교병원 행정업무규정」 제6조(문서의 성립 및 효력)에 따르면 문서는 해당문서에 서명(전자이미지서명, 전자문서서명 및 행정전자서명을 포함한다)의 방식으로 결재함으로써 성립하고, 문서가 수신자에게 도달됨으로써 그 효력이 발생하며, 「부산대학교병원 위임전결규정」 제11조(협의) ①항에 따르면 ‘제3조의 직무권한을 행사함에 있어서 다른 부서와 관련되어 협조를 필요로 하는 사항은 당해 부서장과의 협의를 거쳐야 한다.’라고 명시하고 있다.

3. 감사결과 확인된 문제

각 부서에서는 신규 입사 및 전보 발령, 기타 업무 수행 관련 등의 사유로 PHIS 메뉴 권한이 필요할 시 그룹웨어 “PHIS 메뉴권한 신청서”에 의해 정보

전산팀으로 PHIS 메뉴 권한을 요청하고 있다. 정보전산팀에서는 전산 업무 담당자 별로 메뉴 권한 신청 내용을 구분하여 요청한 부서에 권한을 부여하고 있다.

정보전산팀에서 최근 3년간(2021. 1. 1. ~ 2023. 12. 31.) 부여한 PHIS 메뉴 권한 내역을 살펴본 결과, 타 부서의 권한을 부여할 시에는 관련부서의 협조를 받아야 함에도 구두상으로만 확인 후 내부결재(협조 결재) 등의 절차 없이 권한을 부여한 사실이 확인되었다.

[표 1] PHIS 메뉴 권한 부여 현황

(단위: 건)

년도	PHIS 메뉴 요청	요청 부서 권한 부여	타 부서 권한 부여 (협조 결재 누락)	타 부서 권한 부여 (협조 결재)
2021	153	81	71	1
2022	85	41	43	1
2023	194	119	75	-
합계	432	241	189	2

4. 관계부서 등 의견 및 검토결과

정보전산팀에서는 향후 타 부서의 PHIS 메뉴 권한 부여 시 관련 부서의 협조를 받아 업무를 처리하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

정보전산팀에서 향후 타 부서의 ‘PHIS 메뉴’ 권한 부여 시에는 원 부서의 협조 결재 절차를 거쳐 권한이 부여될 수 있도록 업무 처리 절차를 개선하여 주시기 바랍니다. (개선)

부 산 대 학 교 병 원

권 고

제 목 전산장비 수리(구입) 관련 업무 운영 미흡

소관부서 부산대학교병원 정보전산팀

조치부서 부산대학교병원 정보전산팀

내 용

1. 업무개요

부산대학교병원 정보전산팀 및 정보보안팀에서는 전산기기 도입 계획·설치
운용·유지보수 업무를 수행하며 PC장비를 구매하고 노후화된 장비의 교체
및 수리를 통해 직원들이 병원 업무를 수행하는데 불편함이 없도록 지속적인
노력을 하고 있다.

2. 관련근거(판단근거)

- 부산대학교병원 직제규정 제18조의4, 업무분장규정 제41조의2에 따르면 전
산기기와 관련된 업무는 “정보전산팀”의 업무로 규정하며,

관련규정(판단근거)	세부 내용
부산대학교병원 직제규정	제18조의4(정보전산팀) 1. 전산기기 도입계획의 수립에 관한 사항 11. 전산기기의 설치운용 및 유지보존에 관한 사항
부산대학교병원 업무분장규정	제41조의2(정보전산팀) 1. 전산기기 도입계획의 수립에 관한 사항 11. 전산기기의 설치운용 및 유지보존에 관한 사항
	제42조의2(정보보안팀) 정보보안팀장은 다음 각 호의 업무를 분장한다. 1. (개인)정보보호 정책 수립 및 제·개정 검토 2. (개인)정보보호 관련 예산 편성 및 집행 3. 정보보호 관리체계 수립 및 운영에 대한 관리 및 점검 4. (개인)정보보호 활동 및 운영 현황 점검 및 감독 5. 정보시스템 취약점 진단 및 개선 조치 6. (개인)정보보호관련 인증 및 감사에 관한 사항 7. 침해사고 예방, 분석, 대책 수립에 관한 사항 8. 공공기관 개인정보보호 관리수준진단에 관한 사항 9. 기타 개인정보보호 및 정보보안에 관한 사항

- 부산대학교병원 위임전결규정에 따라 관련 문서의 결재는 최소 과/팀(파트)장의 결재를 받아야 하는 것으로 명시되어 있다.

위임전결규정

◇ 제8조(전결사항)

- ① 병원 각 직위의 전결사항은 별표1과 같이한다.

[별표1] 전결사항

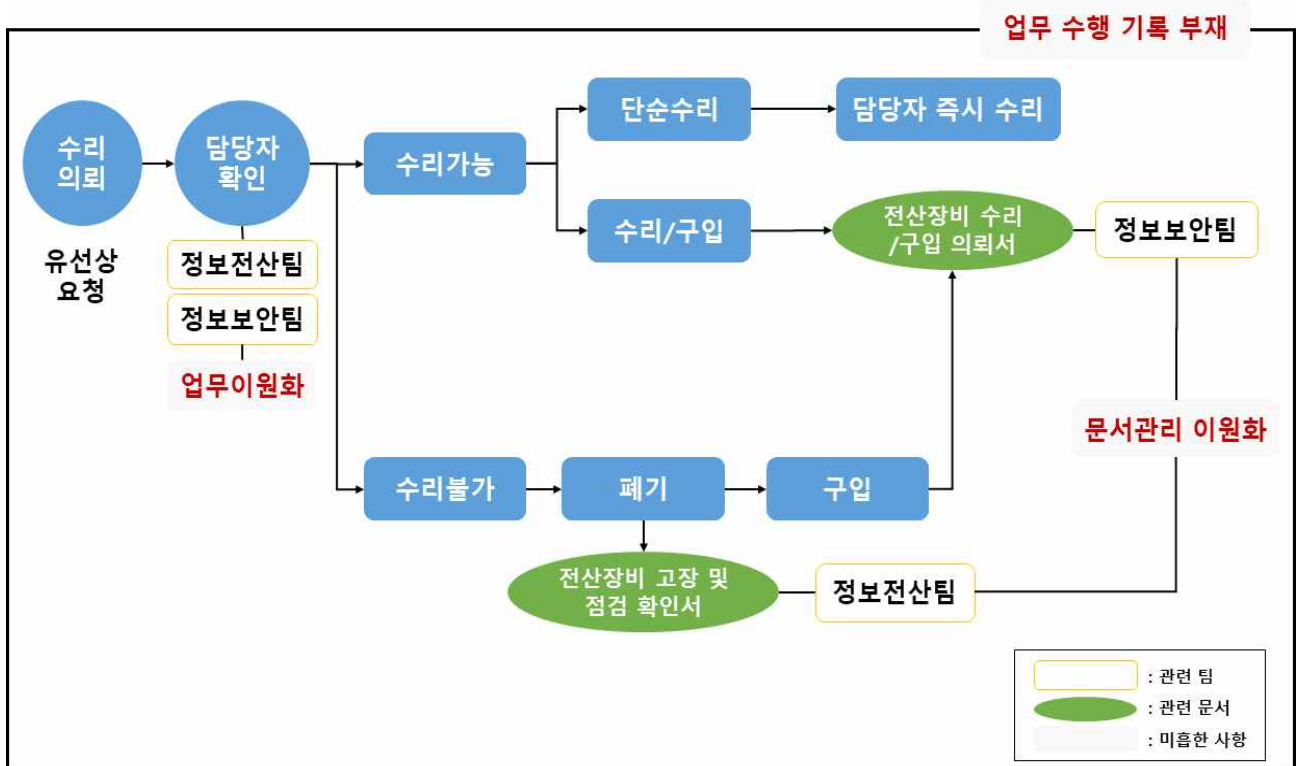
해당 부서	업무명	세부업무내용	원장	감사	결재여부		비고
					부원장· 국·실·소장	과/ 팀(파트)장	
(정보 전산팀)	정보 전산팀 운영	1) 전산업무 일지 2) 출력자료 확인 3) 전산기기 상태 점검결과 보고 9) 장치 신·증설 및 대체	○		○	○ ○	

3. 감사결과 확인된 문제

- 전산장비 수리(구입) 관련 업무의 이원화

전산장비 수리(구입) 관련 업무는 직제규정 제18조의4, 업무분장규정 제41조 2에 따라 정보전산팀의 소관업무로 되어 있고, 정보보안팀의 업무분장에는 전산장비 수리(구입) 업무와 관련한 사항이 명시되어 있지 않다. 하지만 실제로는 [그림 1]과 같이 양 팀(정보전산팀, 정보보안팀)에서 전산장비 수리(구입) 업무를 수행하고 있고 관련 문서 역시 「전산장비 수리/구입 의뢰서」는 “정보보안팀”에서 「전산장비 고장 및 점검 확인서」는 “정보전산팀”에서 각각 관리함에 따라 업무 및 문서관리가 이원화 되어 있는 사실을 확인하였다.

[그림 1] 전산장비 수리(구입) 업무 관련 절차



- 전산장비 수리(구입) 관련 업무 기록 및 이력 관리 미흡

[그림 1]과 같이 전산장비 수리(구입) 의뢰가 문서가 아닌 유선상으로 요청됨에 따라 이와 관련한 업무 기록이 없어 만약 담당 직원이 즉시 수리하여

업무가 종결된 경우라면 실제로 업무를 수행하였음에도 업무의 이력이 남지 않고 있었다. 또한 전산장비 수리(구입) 업무의 진행 상황이 바로 확인되지 않아 담당자간 내용을 공유하기 어려워 보다 효율적인 업무 수행 방안을 마련할 필요성이 확인되었다.

- 전산장비(수리/구입)의뢰서 결재권자의 결재 누락

전산장비(수리/구입)의뢰서는 위임전결규정에 따라 최소 과, 팀(파트)장의 결재가 필요하며, 직원은 결재권자가 아니다. 그럼에도 [표 1]과 같이 지난 3년간(2021. 1. 1. ~ 2023. 12. 31.) 전산장비(수리/구입)의뢰서의 모든 결재건(총 814건)이 담당자의 결재로만 종결되었고 결재권자의 결재가 누락되었음을 확인하였다. 담당자가 매달 전산장비(수리/구입)의뢰서를 취합하여 전산물품(컴퓨터, 모니터, 프린터) 구입과 관련한 보고 및 최종 결정권자의 결재를 받고 있지만, 이와 별개로 전산장비(수리/구입)의뢰서는 그룹웨어 상 문서번호가 부여되는 공문서이기 때문에 부서의 전결사항에 맞게 결재를 받아야 한다. 그러나 현재까지도 이러한 위임전결규정에 부합하지 않게 업무를 진행하고 있어 미흡함이 확인되었다.

[표 1] 전산장비(수리/구입)의뢰서 결재 누락 건수

(단위: 년, 건)

년 도	전산장비(수리/구입)의뢰 건수	결재 누락 건수	비 고
2021	191	191	현재결재선 : 담당자만 결재
2022	284	284	
2023	339	339	
합 계	814	814	

4. 관계부서 등 의견 및 검토결과

정보전산팀 및 정보보안팀에서는 관련 업무 규정을 준수하여 업무를 수행할 예정이며, 양 부서 간 협의하여 적절한 업무 운영 방안을 마련하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

정보전산팀 및 정보보안팀이 전산장비 수리(구입) 관련 업무 절차를 면밀히 검토하시어 향후 규정을 준수하여 업무를 수행할 수 있도록 만전을 기해주시기 바랍니다.
(권고)

부산대학교병원

개 선

제 목 예산 통합 운영 부적정

소관부서 부산대학교병원 정보전산팀

조치부서 부산대학교병원 정보전산팀

내 용

1. 업무개요

부산대학교병원 정보전산팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보체계 개발 계획·분석·설계, 전산기기 도입 계획·설치운용·유지 보수, 전산시스템 및 프로그램 운영·보완 등의 업무를 수행하며 병원 전산 업무 전반에 대한 관리 및 운용 등의 핵심기능을 담당하고 있다.

2. 관련근거(판단근거)

관련규정(판단근거)	세부 내용
부산대학교병원 직제규정	제18조의3(의료정보센터) 의료정보센터에 센터장을 보좌하며 의료정보 업무를 담당할 부센터장을 두되 겸직 교원으로 보하고, <u>정보전산팀, 정보보안팀 및 보건의료정보팀을 두며 각 팀에는 팀장1인을 두되 3급 이상 직원으로 보한다.</u> <개정 2018.5.2.>
	제18조의4(정보전산팀) 정보전산팀장은 다음 각 호의 업무를 분장한다. <개정 2018.5.2.>
	제18조의5(정보보안팀) 정보보안팀장은 다음 각 호의 업무를 분장한다. <개정 2018.5.2.>
부산대학교병원 예산관리지침	제1조(목적) 본 지침은 예산의 편성·운용·통제·사후분석 등 예산관리 전반에 걸친 업무의 절차와 기준을 정함으로써 각 부서의 업무추진을 원활하게 하고 예산절감을 통해 병원의 경영 합리화를 기하고자 하는 것을 목적으로 한다.

3. 감사결과 확인된 문제

현재 정보전산팀과 정보보안팀은 직제규정에 따라 각각의 분리된 팀으로 규정되어 있고 각 팀별로 조직이 구성되어 있다. 이는 정보전산팀과 정보보안팀의 직제가 분리되어 수반되는 모든 업무(예산·인력 운영 등)를 각 팀별로 따로 운영 및 관리해야 함을 의미한다.

그런데 정보전산팀의 예산 현황을 점검한 결과 정보전산팀이 정보보안팀의 예산을 포함하여 예산을 신청해오고 있었고, 정보보안팀의 예산은 별도로 배정되어 있지 않은 것으로 확인되었다.

[표 1]은 2023년 정보전산팀 예산 신청 내역의 일부인 전산장비용역비에 대한 내용이며, 예산신청부서는 정보전산팀이지만 전산장비용역비의 세부 예산 내역 10개 중 7개의 항목이 실제로는 정보보안팀이 사용할 예산으로 확인되었다.

[표 1] 2023년 정보전산팀 예산 신청 내역

(※ 전체 예산 내역 중 전산장비용역비만 발체)

(단위: 원)

계정명	예산내역	예산액	예산신청부서	실 사용팀
전산장비용역비	○ 웹메일 유지보수비	1,980,000	정보전산팀	정보보안팀
	○ 전산시스템 및 데이터베이스 유지보수 용역	294,954,000		
	○ 메인서버 유지보수 용역	154,800,000		
	○ PACS 소프트웨어 유지보수비	179,520,000		
	○ 네트워크 유지보수비	270,200,000		정보전산팀
	○ 그룹웨어 유지보수비	10,440,000		

계정명	예산내역	예산액	예산신청부서	실 사용팀
	○메신저 유지보수비	6,600,000		
	○웹방화벽 및 유해사이트 차단 시스템 유지보수비	6,042,000		정보보안팀
	○바코드 프린트 유지보수비	8,609,000		
	○NAC, DDoS 장비 유지보수비	36,480,000		
소 계		969,625,000		

이처럼 실제 예산을 사용할 부서가 명확하게 구분되어 있음에도 예산을 통합하여 한 팀에서 신청 및 관리해 온 것은 직제 규정에 맞지 않으며, 부서별 예산 편성 및 운용을 통해 각 부서의 업무추진을 원활하게 하고자 하는 예산 관리지침의 목적에도 부합하지 않는다.

4. 관계부서 등 의견 및 검토결과

정보전산팀에서는 관행적으로 해왔던 업무 방식에 대해 다시 한 번 점검할 예정이며, 올바른 업무 절차가 이루어 질 수 있도록 방안을 마련하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

정보전산팀 및 정보보안팀이 향후에는 규정을 준수하여 예산을 분리 운영할 수 있도록 개선하여 주시기 바랍니다. (개선)

부 산 대 학 교 병 원

통 보

제 목 복무 관리 부적정

소관부서 부산대학교병원 정보전산팀

조치부서 부산대학교병원 정보전산팀

내 용

1. 업무개요

부산대학교병원 정보전산팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보체계 개발 계획·분석·설계, 전산기기 도입 계획·설치운용·유지 보수, 전산시스템 및 프로그램 운영·보완 등의 업무를 수행하며 병원 전산 업무 전반에 대한 관리 및 운용 등의 핵심기능을 담당하고 있다.

2. 관련근거(판단근거)

가. 휴가의 허가 관련

「부산대학교병원 복무규정」 제39조(휴가의 허가)에 따르면 ‘직원이 휴가를 실시하고자 할 때에는 사전에 정당한 허가권자로부터 허가를 받아야 한다. 다만, 부득이한 사유로 인하여 사전에 승인을 받지 못하는 경우에는 그 사유를 명백히 하여 사후승인을 받을 수 있다’라고 규정되어 있다.

나. 출장복명서 제출 관련

「부산대학교병원 복무규정」 제14조(출장) 제2항에 따르면 ‘출장자가 귀임 하였을 때는 지체 없이 복명서를 제출하여야 한다. 다만, 경미한 사항이나

비밀을 요하는 사항은 구두로 복명할 수 있다.’라고 규정되어 있다.

3. 감사결과 확인된 문제

가. 각종 휴가 사후 승인 및 육아휴직 미신청

정보전산팀 직원들이 사용한 3년간(2021. 1. 1. ~ 2023. 12. 31.) 각종 휴가에 대한 복무 내역을 확인한 결과, [표 1]과 같이 휴가를 실시하면서 부득이한 사유가 없음에도 불구하고 최소 1일부터 최장 39일까지 부서장의 사전 승인 없이 총 68건의 휴가를 시행한 사실이 확인되었다.

[표 1] 각종 휴가 사후 신청 및 승인현황

연도	사후신청 건수	사후승인 건수	비고
2021년	21건	22건	- 신청 지연일수: 1일~39일 - 승인 지연일수: 1일~39일
2022년	19건	22건	
2023년	23건	24건	
합 계	63건	68건	

그리고 [표 2]와 같이 출산 전후 육아휴직 신청에 있어서도 휴직원 제출로 같음하여 별도의 근태신청 없이 휴직이 허용된 바가 있다. 비록 휴직 발령으로 인해 근태가 인정될 수는 있지만, 근태신청이 누락될 경우 추후 연차 부여 및 각종 휴가(감정노동휴가, 자녀돌봄휴가) 사용에 있어 오류를 범할 수 있는 원인이 될 수 있기에 부서 내에서 관리를 철저히 할 필요성이 있다.

[표 2] 육아휴직 미신청 현황

NO	사번	이름	근태구분	휴가(휴직)기간	근태신청 여부
1			육아휴직(산전)	21.11.01 ~ 22.04.30	미신청
2			출산휴가	22.05.01 ~ 22.07.29	신청
3			육아휴직(산후)	22.07.30 ~ 22.12.29	미신청
4			육아휴직(2차)	22.12.30 ~ 23.07.29	미신청

나. 출장복명서 미제출

정보전산팀 직원들이 신청한 3년간(2021. 1. 1. ~ 2023. 12. 31.) 관외출장 내역을 확인한 결과, [표 3]과 같이 출장을 실시하고도 출장복명서를 미제출한 사실을 확인하였다.

[표 3] 출장복명서 미제출 현황

사번	이름	출장일자	출장지	출장목적
		2023.01.17	국가임상시험지원재단	최종보고회 참석 (임상시험 네트워크)

4. 관계부서 등 의견 및 검토결과

정보전산팀에서는 소속 직원들에게 복무 관련 내용을 교육하여 향후에는 이런 일이 재발되지 않도록 노력하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

직원들이 휴가 등을 실시할 경우에는 사전승인을 받은 후 휴가를 사용하도록 하고 부득이한 사유로 사후 승인을 받아야 할 경우에는 반드시 그 사유를 명백히 기록하도록 하고, 각종 출장을 실시 할 경우에도 출장 귀임 후에는 지체 없이 출장복명서를 제출하도록 조치하시기 바랍니다. (통보)

부 산 대 학 교 병 원

권 고

제 목 정보보호 및 개인정보보호 업무 운영에 관한 사항

소관부서 부산대학교병원 정보보안팀

조치부서 부산대학교병원 정보보안팀

내 용

1. 업무개요

부산대학교병원 정보보안팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보보호 관리체계(ISMS) 수립 및 운영, 정보시스템 취약점 진단 및 개선, 침해사고 예방·분석·대책 수립 등의 업무를 수행하며 정보보안을 강화하고 각종 보안 위협으로부터 병원 내 정보를 안전하게 보호 및 유지하는데 기여한다.

2. 관련근거(판단근거)

- 정보보안팀은 다음과 같은 필요성[① 일률적인 업무처리 어려움 ② 각종 외부 평가에서 정보보호 전담조직 부재로 결함 및 감점 사항 지적 ③ 정보보호 관련 병원의 사회적 책임 및 요구 증대]으로 인해 2018.05.02.자로 직제 신설
- 직제규정 제18조의5 및 업무분장규정 제42조의2에 따르면 개인정보보호와 정보보호 업무는 정보보안팀에서 담당한다고 명시되어 있으나, (**※조직 신설 목적에 부합**)
- 정보보호조직운영지침에 따르면 개인정보보호와 정보보호 업무는 정보보호

담당자(보건의료정보팀)가 수행 (※기술적 부분은 정보보안팀에서 협조)

<정보보호 및 개인정보보호 업무 정의>

구분	정보보호	개인정보보호
법령	정보통신망법	개인정보 보호법
정책기관	과학기술정보통신부	개인정보보호위원회
목적	병원의 정보자산을 내·외부의 위협으로부터 안전하게 보호	
최고 책임자	정보보호 최고책임자(CISO)	개인정보 보호책임자(CPO)
	진료부원장	
병원위원회	(개인)정보보호위원회	
주요업무	○ 정보보호 관리체계의 수립 및 관리·운영 ○ 정보보호 관련 법률 검토 ○ 정보보호를 위한 교육 및 홍보 관리 ○ 정보보호 취약점 분석·평가 및 개선	○ 개인정보 보호 계획의 수립 및 시행 ○ 개인정보 수집, 이용, 제공, 파기 등 관리업무 ○ 개인정보에 대한 접근권한 및 규정 관리업무 ○ 개인정보를 위한 교육 및 홍보에 관한 업무
공통업무	○ 보안감사 (정보보안 조치점검, 개인정보보호 점검 등) 수행 ○ 정보보호 및 개인정보보호 기술적 보호조치 업무 ○ 중요 정보의 암호화	

구분

정보보호

개인정보보호

정보보호관리체계(ISMS)

주요정보통신기반시설

개인정보보호 관리수준진단

개인정보 영향평가

구분

통합인증

분야(인증기준 개수)

ISMS-P

ISMS

1.관리체계 수립 및 운영(16)

1.1 관리체계 기반 마련(6)
1.3 관리체계 운영(3)

1.2 위험관리(4)
1.4 관리체계 점검 및 개선(3)

2.보호대책 요구사항(64)

2.1 정책, 조직, 자산 관리(3)
2.3 외부자 보안(4)
2.5 인증 및 권한 관리(6)
2.7 암호화 적용(2)
2.9 시스템 및 서비스 운영관리(7)
2.11 사고 예방 및 대응(5)

2.2 인적보안(6)
2.4 물리보안(7)
2.6 접근통제(7)
2.8 정보시스템 도입 및 개발 보안(6)
2.10 시스템 및 서비스 보안관리(9)
2.12 재해복구(2)

-

3.개인정보 처리단계별 요구사항(21)

3.1 개인정보 수집 시 보호조치(7)
3.3 개인정보 제공 시 보호조치(4)
3.5 정보주체 권리보호(3)

3.2 개인정보 보유 및 이용 시 보호조치(5)
3.4 개인정보 파기 시 보호조치(2)

인증 및 평가

※ 병원에서는 정보보호관리체계(ISMS)만 의무사항으로 수행하고 있지만 정보보호와 개인정보보호를 통합한 정보보호관리체계(ISMS-P) 인증을 마련해 놓고 있음.

3. 감사결과 확인된 문제

정보보호 및 개인정보보호 운영 적정성을 확인하고자 업무 이행 사항을 검토한 결과, [표 1]과 같이 규정과 지침에서 정한 업무담당부서가 상이하게 명시되어 있어 업무 구분이 어려운 상황이지만, 실제 운영부분을 보면 ‘(개인) 정보보호 관련’ 관리적 부분은 정보보호 관리자(보건의료정보팀)가 담당하고, 기술적 부분은 정보보안팀에서 담당하고 있어 「정보보호조직운영지침」(정보보호위원회 조직)에 따라 운영되고 있다. 이는 정보보안팀 신설의 취지(개인정보보호와 정보보호 분야를 일률적으로 담당)와 규정에 부합되지 않고 있는 상황이다.

[표 1] 개인정보보호 및 정보보호 업무 분장 부적정

구분	업무소관 (개인정보보호 / 정보보호)	비고
직제규정/업무분장규정/ 위임전결규정	정보보안팀(전담조직)	- 전담조직 역할 미이행 - 규정 및 지침에 맞지 않게 운영
정보보호조직운영지침 (실제운영)	정보보호 관리자(보건의료정보팀) ※ 기술적 부분은 정보보안팀 담당	- 관리적 및 기술적 부분을 구분하여 업무 보고 (결재선 지정)

※ 정보보호 담당자(보건의료정보팀)가 정보보안팀 파견 당시 관리적 업무에 대한 보고는 아래와 같음.

관리적 부분 업무 보고 체계

정보보안 담당자(기안) → 보건의료정보팀 um → 보건의료정보팀장 → 정보전산팀장/정보보안팀장
(협조) → 의료정보센터장 → 진료부원장 → 병원장(최종결재)

그리고 업무 운영 부분에 있어서도 정보보안팀 신설 당시 전담조직으로서의 업무를 충실히 이행하고자 보건의료정보팀 소속 정보보호 담당자를 파견 조치 하는 등 체계적인 운영을 위해 노력하였으나, 업무 분장에 양 부서간의 이견 이 있어 운영상 어려움이 있었고, 추후에는 정보보호 담당자마저 2023년 09 월 01일자로 파견이 해제되는 등 전담조직의 역할이 여전히 이행되지 못하고 있는 실정이다.

따라서 병원에서는 정보보호와 개인정보보호 업무가 효율적으로 수행될 수 있도록 관련 법령 및 지침, 전담조직 운영, 인증체계 등을 고려하여 역할과 책임을 명확히 할 필요성이 있다.

검토 사항

(1안) 정보보안팀에서 현재 운영하고 있는 기술적인 보안 외 정보보안의 관리업무를 겸업하지 못한다고 하면 (개인)정보보호위원회를 개최하여 규정 및 지침을 재 정비

(2안) 전담조직(정보보안팀)의 역할 수행을 위한 인력 구성이 어려워 별도로 운영되고 있는 경우라면 병원 집행부와 협의를 통해 적절한 방안 마련

4. 관계부서 등 의견 및 검토결과

정보보안팀에서는 해당사안에 대해 면밀히 검토한 후 관련부서 협의 및 위원회 개최를 통해 적절한 업무 운영 방안을 마련하는데 노력하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

해당사안에 대한 운영 적정성 여부를 판단하여 적절하게 조치될 수 있도록 방안을 마련하시기 바랍니다. (권고)

부 산 대 학 교 병 원

주 의

제 목 네트워크 및 프로그램 설치에 대한 관리 미흡

소관부서 부산대학교병원 정보보안팀

조치부서 부산대학교병원 정보보안팀

내 용

1. 업무개요

부산대학교병원 정보보안팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보보호 관리체계(ISMS) 수립 및 운영, 정보시스템 취약점 진단 및 개선, 침해사고 예방·분석·대책 수립 등의 업무를 수행하며 정보보안을 강화하고 각종 보안 위협으로부터 병원 내 정보를 안전하게 보호 및 유지하는데 기여한다.

2. 관련근거(판단근거)

관련 지침

◇ IT 보안지침 제37조(네트워크 접속통제)

- ② 병원 내에서는 사용 승인을 받지 않은 단말기를 활용하여 네트워크 접속을 금지한다.

◇ IT 보안지침 제39조(네트워크 보안관리)

- ② 병원 전산망의 지속적·안정적 운영을 확보하기 위하여 정보전산팀에서 통합관리 한다.

◇ IT 보안지침 제40조(IP주소 보안관리)

- ③ 네트워크 담당자는 사용자에게 부여하는 IP주소를 개인별로 부여하고, 기록 · 관리하여야 한다.
④ 병원은 승인을 받지 않은 비인가자에게 IP주소를 부여할 수 없다.

◇ 물류관리팀-167(2021.01.13.)「'기부채납 및 의국비' 자산 관련 지원 및 제한사항 안내」

○ 지원사항

- 컴퓨터본체 구매 시 인터넷 연결
- 원내 프로그램 설치 (그룹웨어, PHIS, PACS, V3, 이글아이, PC지킴이, 원내 메신저)
- ※ 지원불가대상: 병원 프로그램을 제외한 모든 소프트웨어

○ 제한사항

- 기부채납 및 의국비 자산에 대한 모든 소모품 구입 및 수리비용(사후관리) 지원 불가

3. 감사결과 확인된 문제

최근 3년간(2021. 1. 1. ~ 2023. 12. 31.) 정보보안팀에 제출한 ‘네트워크 및 IP 주소 서비스 신청서’ 내역을 확인한 결과, 서비스 신청 부분은 다음과 같은 사항들[신청자산의 기부채납 여부, 신청자산 정보 사항(이동형 자산 여부, 자산코드 등), 비인가자 및 비인가제품 여부]이 신청서 내역에 누락되어 있어 검토 부분이 미흡하였고, 서비스 승인 부분에 있어서는 「IT 보안지침」상 네트워크 보안관리 부분은 정보전산팀에서 통합 관리한다고 명시되어 있지만, 실제 권한 부여 및 관리는 정보보안팀에서 담당하고 있어 서비스 신청에 대한 승인 검토 및 관리가 [표 1]과 같이 부적정하게 처리되고 있는 사실이 확인되었다.

[표 1] 네트워크 서비스 신청 부적정 현황

(조사기간: 2021. 1. 1.~2023. 12. 31.)

연도	신청 건수		부여권자	최종결재권자	부적정 사항
	네트워크	IP 신청서			
2021년	277건	-	네트워크 담당자	정보보안팀장	- 신청서 내역 미흡 - 정보전산팀장 협조 사항 없음 (결재 x) - 지침상 '서비스 신청 승인 권한자' 별도로 지정하지 않음
2022년	225건	-	네트워크 담당자	정보보안팀장	
2023년	156건	138건	네트워크 담당자	정보보안팀장	

- 2021년 ~ 2023년 6월: 네트워크 신청서로 IP 주소 신청 / 이후부터 별도 구분하여 신청서 관리

마지막으로 행정적인 차원에서 다음과 같은 사항들 [①원내 프로그램 설치의 경우, 별도의 신청서로 접수 되고 있지 않아 어떤 프로그램(그룹웨어, 이글아이 등)이 설치되었는지 그리고 병원자산에 설치되었는지 확인 불가 ②수리 부분에 있어서도 해당 신청서 내 자산구분(병원자산, 개인자산, 기부채납)이 없어 내부지침 대로 병원자산에 한해서만 수리가 되는지 확인 불가]이 이행되고 있지 않는 점은 정보자산 기록(문서화) 및 관리에 있어 미흡한 부분이다.

4. 관계부서 등 의견 및 검토결과

정보보안팀에서는 미비한 부분에 대하여 면밀히 검토한 후 정비하고, 관련 지침에 위반되지 않도록 철저히 관리하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

IP주소 부여 및 원내 프로그램 설치 시 PC 제품에 대해 병원자산 여부 등을 확인한 후 이행하여 주시기 바라며, 지도·감독을 소홀히 한 부서장 및 관련 부서인 정보전산팀 부서장에게는 [주의] 조치하여 주시기 바랍니다. (주의)

[관련자]	부산대학교병원	정보보안팀	전산◎급	○○○	【주의】
		정보전산팀	전산●급	●○○	【주의】

부 산 대 학 교 병 원

주 의

제 목 VPN 사용승인 및 관리 미흡

소관부서 부산대학교병원 정보보안팀

조치부서 부산대학교병원 정보보안팀

내 용

1. 업무개요

부산대학교병원 정보보안팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보보호 관리체계(ISMS) 수립 및 운영, 정보시스템 취약점 진단 및 개선, 침해사고 예방·분석·대책 수립 등의 업무를 수행하며 정보보안을 강화하고 각종 보안 위협으로부터 병원 내 정보를 안전하게 보호 및 유지하는데 기여한다.

2. 관련근거(판단근거)

관련 지침

◇ IT 보안지침 제37조(네트워크 접속통제)

- ② 내부 네트워크는 외부에서 모니터링 및 유지보수를 위한 관리목적의 원격 접속을 할 수 없다. 단, 특수한 목적에 의해 외부에서 내부 네트워크에 접속이 필요한 경우 기술보안 관리자의 승인을 받아야 한다. (기술보안 관리자: 정보보안팀장)

◇ 사용자보안지침 제19조(원격접근통제 기본원칙)

- ③ 임직원의 원격 접근 시 요청 사유, 사용 기한, 신청자, 접근 범위, 작업 내용 등을 'VPN 서비스 신청서' 내 작성하여 정보보호 담당자의 승인을 받아야 한다. (정보보호 담당자: 보건의료정보팀 팀원)

3. 감사결과 확인된 문제

최근 3년간(2021. 1. 1. ~ 2023. 12. 31.) VPN 계정 사용을 위해 정보보안팀에 제출한 ‘VPN 서비스 신청서’ 내역을 확인한 결과, 먼저 VPN 사용 승인 결정에 있어서는 다음과 같은 문제점들 [①각 지침(IT 보안지침, 사용자보안지침)에 명시된 ‘사용 승인 권한자’가 다름 ②현행 상 실제 승인은 업무 담당자(기술보안 담당자: 정보보안팀 팀원)가 권한 부여]이 발견되어 [표 1]과 같이 VPN 사용 승인이 부적절하게 관리되고 있는 사실이 확인되었다.

[표 1] VPN 서비스 사용 승인 부적정 현황

(조사기간: 2021. 1. 1.~2023. 12. 31.)

연도	신청건수	승인 여부			비 고
		정보보호 담당자 (사용자보안지침)	기술보안 관리자 (IT 보안지침)	기술보안 담당자 (현행)	
2021년	82건	×	○	△	<신청서 결재라인> 서무 → 기술보안 담당자 → 기술보안 관리자(최종결재) ※ 단, 사용승인 권한여부는 기술보안 담당자가 결정
2022년	148건	×	○	△	
2023년	206건	×	○	△	
합 계	436건	‘지침상’ 승인 권한자		‘업무상’ 담당자	

그리고 VPN 신청서 양식 부분을 검토한 결과, 사용자보안지침에 따른 VPN 서비스 신청서 내 필수 작성 항목 부분 중 ‘사용 기한’에 대한 사항이 기록되고 있지 않았다. 실제로는 담당자의 검토 및 확인절차 후 원격 접근이 승인되고 있지만, 행정적으로나 여러 측면에서 보았을 때 문서상에 기재되어 있지 않으면 미이행 사항으로 간주될 수 있는 부분임에 따라 신청서 내용을 보완하여 운영할 필요성이 있다.

4. 관계부서 등 의견 및 검토결과

정보보안팀에서는 관련 지침을 재검토하여 현행 상 미비한 부분을 개정하고,

정보보안 강화에 노력하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

외부에서 내부 네트워크 접속 승인에 대한 사항을 면밀히 검토한 후 현행에 맞게 지침을 개정하여 주시기 바라며, 지도·감독을 소홀히 한 부서장 및 관련 부서인 정보전산팀 부서장에게는 [주의] 조치하여 주시기 바랍니다. **(주의)**

[관련자] 부산대학교병원 정보보안팀 전산◇급 ◇◇◇ **【주의】**

정보전산팀 전산◆급 ◆◆◆ **【주의】**

부 산 대 학 교 병 원

주의 및 통보

제 목 유지보수 용역 관리에 관한 사항

소관부서 부산대학교병원 정보보안팀

조치부서 부산대학교병원 정보보안팀

내 용

1. 업무개요

부산대학교병원 정보전산팀 및 정보보안팀에서는 전산장비 및 프로그램, 시스템 소프트웨어, 하드웨어, 네트워크, 데이터베이스 운용, 정보 시스템 조정 및 보완, 전산기기 설치 운용 및 유지 등의 효율적이고 안정적인 운영을 위하여 업무별 유지보수 용역 계약을 체결하여 업무를 수행하고 있으며, 용역별 특별히 필요한 제반 사항을 용역 계약 특수조건(과업지시서)에 규정하여 유지보수 업무를 관리하고 있다.

2. 관련근거(판단근거)

관련규정(판단근거)	세부 내용
용역계약 특수조건 (과업지시서)	용역별 유지보수 특수조건(과업지시서) 세부 사항
부산대학교병원 직제규정	제18조의4(정보전산팀) 10. 전산시스템 및 프로그램 운용 및 보완에 관한 사항 11. 전산기기의 설치운용 및 유지보수에 관한 사항 12. 시스템 소프트웨어 관리에 관한 사항 13. 데이터베이스 운용 및 관리에 관한 사항 14. 정보시스템 조정 및 보완에 관한 사항
부산대학교병원 업무분장규정	제41조의2(정보전산팀) 10. 전산시스템 및 프로그램 운용 및 보완에 관한 사항 11. 전산기기의 설치운용 및 유지보수에 관한 사항 12. 시스템 소프트웨어 관리에 관한 사항 13. 데이터베이스 운용 및 관리에 관한 사항 14. 정보시스템 조정 및 보완에 관한 사항

3. 감사결과 확인된 문제

정보전산팀 및 정보보안팀에서 최근 3년간(2021. 1. 1. ~ 2023. 12. 31.) 수행한 유지보수 관리 현황을 살펴본 결과, [표 1]과 같이 용역계약 특수조건(과업지시서)에 명시된 유지보수 업무 범위를 미이행한 사실을 확인하였다.

[표 1] 용역별 유지보수 관리 현황

관리부서	유지보수 영역명	용역계약 특수조건(과업지시서)	미이행 사항
정보보안팀	네트워크 유지보수	제7조(점검 및 보고서) ① 유지보수 종합계획서 연1회 제출	2021년, 2023년 종합계획서 제출 누락
	전산시스템 및 데이터베이스 유지보수	제14조(장애복구 조치완료) 장애발생 통보 후 1시간 이내 도착, 8시간 이내 완료 한다. 초과한 경우 '제23조' 지체상금을 산정한다	장애보고서 리포트 상 장애 완료 시간 누락
	바코트 프린터 유지보수	제5조(정비 보수 사항) 4. "을"은 계약 체결 후 정비 보수 List 및 설치 장비 매뉴얼을 준비하여 '갑'에게 1회 이상 교육 실시	교육 미실시

정보전산팀	그룹웨어 및 메신저 유지보수	제3조(유지보수) ⑦ 중급이상의 엔지니어 전담요원 배치	자격증 미소지
-------	--------------------	-----------------------------------	---------

그리고 직제규정 제18조의4(정보전산팀) 및 업무분장규정 제41조의2(정보전산팀) 제10항 ~ 14항에 따르면 전산 시스템 및 프로그램 운용 및 보완, 전산기기의 설치운용 및 유지보존, 시스템 소프트웨어 관리, 데이터베이스 운용 및 관리, 정보시스템 조정 및 보완에 관한 사항은 정보전산팀 업무로 규정하고 있다. 그런데 현재 전산기기, 전산시스템, 정보시스템 등의 유지보수 업무 관리에 대해 정보보안팀에서도 관련 업무를 수행하고 있는 것이 확인되었고, 정보보안팀의 직제규정 및 업무분장규정에는 이와 관련된 업무 내용은 명시되어 있지 않아 규정에 맞지 않게 업무를 수행하고 있다.

4. 관계부서 등 의견 및 검토결과

정보전산팀 및 정보보안팀에서는 부서 간 협의하여 적절한 업무 운영 방안을 마련하고, 유지보수 업무 관리에 있어 향후 유사한 사례가 반복되는 일이 없도록 하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

정보전산팀 및 정보보안팀에서는 부서 간 협의하여 유지보수 업무가 규정에 맞게 수행될 수 있도록 적절한 방안을 마련하시고, **(통보)** 향후 유사한 사례가 반복되는 일이 없도록 유지보수 업무에 만전을 기해주시고, 지도·감독을 소홀히 한 관리자에게는 **【주의】** 조치하여 주시기 바랍니다. **(주의)**

[관련자]	부산대학교병원	정보보안팀	전산☞급	☞☞☞	【주의】
		정보전산팀	전산☒급	☒☒☒	【주의】
		정보전산팀	전산■급	■□□	【주의】

부 산 대 학 교 병 원

통 보

제 목 복무 관리 부적정

소관부서 부산대학교병원 정보보안팀

조치부서 부산대학교병원 정보보안팀

내 용

1. 업무개요

부산대학교병원 정보보안팀에서는 관련 법령 및 병원 규정(정책, 지침) 등에 따라 정보보호 관리체계(ISMS) 수립 및 운영, 정보시스템 취약점 진단 및 개선, 침해사고 예방·분석·대책 수립 등의 업무를 수행하며 정보보안을 강화하고 각종 보안 위협으로부터 병원 내 정보를 안전하게 보호 및 유지하는데 기여한다.

2. 관련근거(판단근거)

가. 휴가의 허가 관련

「부산대학교병원 복무규정」 제39조(휴가의 허가)에 따르면 ‘직원이 휴가를 실시하고자 할 때에는 사전에 정당한 허가권자로부터 허가를 받아야 한다. 다만, 부득이한 사유로 인하여 사전에 승인을 받지 못하는 경우에는 그 사유를 명백히 하여 사후승인을 받을 수 있다.’라고 규정되어 있다.

나. 출장복명서 제출 관련

「부산대학교병원 복무규정」 제14조(출장) 제2항에 따르면 ‘출장자가 귀임

하였을 때는 지체 없이 복명서를 제출하여야 한다. 다만, 경미한 사항이나 비밀을 요하는 사항은 구두로 복명할 수 있다'라고 규정되어 있다.

3. 감사결과 확인된 문제

가. 각종 휴가 사후 승인

정보보안팀 직원들이 사용한 3년간(2021. 1. 1. ~ 2023. 12. 31.) 각종 휴가에 대한 복무 내역을 확인한 결과, [표 1]과 같이 휴가를 실시하면서 부득이한 사유가 없음에도 불구하고 최소 1일부터 최장 14일까지 부서장의 사전 승인 없이 총 31건의 휴가를 시행한 사실이 확인되었다.

[표 1] 각종 휴가 사후 신청 및 승인현황

연도	사후신청 건수	사후승인 건수	비고
2021년	11건	12건	- 신청 지연일수: 1일~12일 - 승인 지연일수: 1일~14일
2022년	06건	08건	
2023년	08건	11건	
합 계	25건	31건	

나. 출장복명서 미제출

정보보안팀 직원들이 신청한 3년간(2021. 1. 1. ~ 2023. 12. 31.) 관외출장 내역을 확인한 결과, [표 2]와 같이 출장을 실시하고도 출장복명서를 미제출한 사실을 확인하였다.

[표 2] 출장복명서 미제출 현황

NO	사번	이름	출장일자	출장지	출장목적
1			2021.11.21	서울교육대학교	보안대책 회의 참석 (국립대병원 취약점)
2			2022.01.13	(주)아이티아이즈	워크샵 참석 (마이헬스웨이사업)
3			2022.10.18	대구 메리어트호텔	심포지엄 참석 (임상시험 네트워크)

4. 관계부서 등 의견 및 검토결과

정보보안팀에서는 소속 직원들에게 복무 관련 내용을 교육하여 향후에는 이런 일이 재발되지 않도록 노력하겠다는 의견을 제시하였다.

조치할 사항 부산대학교병원장은

직원들이 휴가 등을 실시 할 경우에는 사전승인을 받은 후 휴가를 사용하도록 하고 부득이한 사유로 사후 승인을 받아야 할 경우에는 반드시 그 사유를 명백히 기록하도록 하고, 각종 출장을 실시 할 경우에도 출장 귀임 후에는 지체 없이 출장복명서를 제출하도록 조치하시기 바랍니다. **(통보)**